

ISE 331: Fundamentals of Computer Security

Practice Problems for Lectures 27 to 29 (Software, Ethics)

Directions: Below is a set of exercises and problems you should do for practice. Answering this set of questions should be just one part of your preparation for quizzes and exams. In addition to solving these problems you should:

- Review the lecture notes.
- Review your homework assignments.
- Form a study group and test each other on the material.

Note: The solution is provided on the last page. It is strongly recommended that you work on the questions first before going to the solution.

Part I. Multiple Choice

1. Which best describes the differences between symbolic execution and dynamic testing?
 - A. Symbolic execution can handle infinite number of paths in a program, but dynamic testing cannot.
 - B. Symbolic execution is sound but not complete, while dynamic testing is complete but not sound.
 - C. One symbolic execution can represent many actual program runs, but one dynamic testing covers only one.
 - D. Symbolic execution cannot handle loops in the source code, but dynamic testing can.
2. What is a primary advantage of Concolic Execution (Dynamic Symbolic Execution) over pure symbolic execution?
 - A. It eliminates the path explosion problem for programs containing loops.
 - B. It can fall back to concrete values when dealing with system calls or libraries.
 - C. It does not need SMT (Satisfiability Modulo Theories) or SAT (Satisfiability) solvers.
 - D. It guarantees that all possible paths can be explored in a single execution even with limited resources.
3. What does an SMT (Satisfiability Modulo Theories) solver do in symbolic execution?
 - A. Determine if a specific path in the program is feasible.
 - B. Optimize the code coverage of each symbolic execution.
 - C. Convert source codes so that they can handle symbolic execution.
 - D. Decide which path to go when encountering branches in execution.
4. A symbolic execution algorithm tracks the number of times each statement in a program is executed, to prioritize taking branch paths that goes to less-executed code. This describes:
 - A. Random Path Search
 - B. Breadth-First Search (BFS)
 - C. Coverage-Guided Search
 - D. Depth-First Search (DFS)
5. Which is NOT an example of side channel attack?
 - A. Distinguish 0 and 1 bit in the password using power analysis.
 - B. Determine the unlock pattern of a smartphone using accelerometer data.
 - C. Inject voice commands to a microphone using modulated light.
 - D. Find the password to an online account using repeated trial-and-error.
6. Which is true about the Spectre attack?
 - A. It depends on a software bug like buffer overflow to work.
 - B. It exploits execution speculation and cache timings to read arbitrary memory.
 - C. It needs the attacker to obtain root privilege to perform the attack.
 - D. It uses information leaked from power and electromagnetic side channels.

7. Which is true regarding branch speculation used in modern CPUs?
- A. The instruction after the branch will still be executed even if the speculation is wrong, and the CPU will NOT act to undo the execution immediately.
 - B. The instruction after the branch will still be executed even if the speculation is wrong, but the CPU will act to undo the execution immediately.
 - C. The instruction and relevant data after the branch will be stored in the cache even if the speculation is wrong, and the CPU will NOT act to remove them from the cache immediately.
 - D. The instruction and relevant data after the branch will be stored in the cache even if the speculation is wrong, but the CPU will act to remove them from the cache immediately.
8. ____ is NOT a valid reason to use side channel to detect intrusions in a system.
- A. Side channel analysis has perfect precision (False Positive Rate = 0).
 - B. Side channel analysis can reliably detect anomaly in stable environments.
 - C. Side channel analysis can be done without Internet connection.
 - D. Side channel analysis does not need constant software updates.
9. A developer stops maintaining an open-source tool used to bypass a specific encryption algorithm because they conclude that the tool's negative consequences for user privacy now outweigh its benefits for security research. This developer's decision-making is primarily based on which kind(s) of ethics?
- A. Utilitarianism
 - B. Deontological
 - C. Both utilitarianism and deontological
 - D. Neither utilitarianism nor deontological
10. A printer company made a printer that can only print if the ink is also made by the company. Which option below best matches **deontological** analysis of this practice?
- A. The company did nothing wrong, because they could earn more money and fund their research, encouraging innovation.
 - B. The company should be blamed, because forcing users to buy their ink makes more people unhappy, and increases financial harm.
 - C. The company did nothing wrong, because current laws do not explicitly prohibit the company from using this type of design.
 - D. The company should be blamed, because it violates a buyer's fundamental right to use their own property as they see fit.

Part II. True or False

- 1. Symbolic execution is complete, meaning if it reports an error, the program definitely has bug(s).
- 2. In the context of symbolic execution, path explosion means that some paths in the program are dead ends.
- 3. SMT solvers can only handle Boolean operation formulas; formulas with arithmetic operations can only be solved by SAT solvers.
- 4. Side channel can only be used to perform an attack on a computer system.
- 5. Hardware running constant-time password verification algorithm can still be vulnerable to side channel attacks.
- 6. A side channel attack requires physical access to the target computer, and cannot be performed remotely.
- 7. There is no universal consensus that renders deontological framework to be superior to utilitarianism, or vice versa.
- 8. Because deontological and utilitarianism frameworks prioritize different values, they will contradict each other and lead to opposite conclusions for every security scenario.

Part III. Short Answer

1. Using symbolic execution, analyze the possible paths for the program below. For each path, identify the constraints on the input variables a and b and determine the corresponding return value. Provide concrete values for each path.

```
int compute(int a, int b) {  
    if (a < 5) {  
        if (a + b == 10) {  
            return 1;  
        } else {  
            return 2;  
        }  
    } else {  
        if (b > 20) {  
            return 3;  
        } else {  
            return 4;  
        }  
    }  
}
```

2. Using symbolic execution, analyze the possible paths the below program can take based on the conditions. For each path, identify the constraints on the input variables x and y and determine the corresponding output. Provide concrete values for each path.

```
#include <stdio.h>
```

```
// Assume x and y are initialized as symbolic input values
```

```
int main() {  
    int x = get_symbolic_input();  
    int y = get_symbolic_input();  
  
    if (x * 2 > y) {  
        x = x - 5; // State mutation  
        if (x + y == 0) {  
            printf("Outcome A\n");  
        } else {  
            printf("Outcome B\n");  
        }  
    } else {  
        if (y > 10) {  
            printf("Outcome C\n");  
        } else {  
            printf("Outcome D\n");  
        }  
    }  
    return 0;  
}
```

3. A spectre-type attack exploits the following code running in a victim process in loops. The attacker controls `x` and can access `array2`. `sec` is an array containing sensitive data. The attacker knows its address and wants to read it, but can't read directly.

```
if (x < array1_size) {  
    y = array2[array1[x] * 4096];  
}
```

- Explain how the attacker can use branch training to make the CPU load `array2[sec[index] * 4096]` into the cache.
 - After the CPU load `array2[sec[index] * 4096]` into the cache, how does the attacker determine the value of `sec[index]`?
 - A "memory fence" function can be added between the if condition and the assignment of `y` statement, to mitigate the attack. What can this function do to prevent the spectre attack? Provide one possibility.
4. Besides timing side channel, name two other physical side channels. For each, briefly describe an example of this side channel leak.
5. Analyze the following problem from the perspective of Consequentialist and Deontological ethics:
A university research team wants to download a publicly leaked, stolen dataset containing the biometric profiles of two million corporate employees. The team intends to use the data to study demographic biases and develop safer global security standards. However, an association representing the affected employees has explicitly stated they do not consent to researchers accessing or analyzing their stolen information, citing an ongoing violation of their privacy.

Part I Solution:
1-5 CBACD 6-10 BCAAD

Part II Solution:
1-5 TFFFT 6-8 FTF

Part III Solution:

1. Each return value represents one path, and they are mutually exclusive.

Path (Return Value)	Path Constraints (Logical)	Concrete Example (other values are fine as long as they satisfy the corresponding constraints)
1	$a < 5 \ \&\& \ a + b == 10$	$a = 2, b = 8$
2	$a < 5 \ \&\& \ a + b != 10$	$a = 2, b = 4$
3	$a >= 5 \ \&\& \ b > 20$	$a = 5, b = 30$
4	$a >= 5 \ \&\& \ b <= 20$	$a = 5, b = 10$

2. Each printf() call represents one path, and they are mutually exclusive.

Path (Return Value)	Path Constraints (Logical)	Concrete Example (other values are fine as long as they satisfy the corresponding constraints)
1 (A)	$2x > y \ \&\& \ x + y = 5$	$x = 2, y = 3$
2 (B)	$2x > y \ \&\& \ x + y != 5$	$x = 2, y = 2$
3 (C)	$2x <= y \ \&\& \ y > 10$	$x = 2, y = 12$
4 (D)	$2x <= y \ \&\& \ y <= 10$	$x = 2, y = 8$

- 3.
- The attacker controls x to make the if condition true multiple times, which trains the CPU to expect the condition to be true. He then changes x to make (the address of array1) + x equal to (the address of sec) + index. CPU will pull the specific page of array2 (starting with $\text{array2}[\text{sec}[\text{index}] * 4096]$) into the cache before the if check finishes.
 - The attacker tries to access all elements in array2, and the page that is pulled into the cache can be accessed much faster than those not in cache (assume attacker flushes the cache before speculation). By recording access time, the attacker can determine the value of $\text{sec}[\text{index}]$.
 - The function could stop the CPU from loading cache until the conditional evaluation is completed.
4. Power side channel can leak bits in keys, appliances being used, screen pattern and brightness, etc.
Acoustic side channel can leak keyboard strokes.
Acceleration side channel can leak smartphone unlock pattern or pins.

5. **Consequential Analysis:** This framework evaluates the morality of the action based on its net consequences.

Harms vs. Benefits: The data is already leaked and made public, researching the data causes no new physical or financial harm, only minor psychological distress to victims. On the other hand, the benefits of uncovering structural biases and fixing global biometric standards are immense.

Conclusion: Ethically acceptable because benefits outweigh the harms.

Deontological Analysis: This framework evaluates the morality of the action based on duties, rights of people, and does not depend on consequences.

Duties and Rights: Individuals have an absolute right to privacy and control over their biometric data. Analyzing the stolen data is against their wishes, does not respect the rights of privacy, and against the moral duty of not using stolen items or data.

Conclusion: Ethically unacceptable because does not respect rights of people and does not fulfill researchers' moral duty.